

06_DISASTER_RECOVERY

- [SUOP ERP v1.0 — Enterprise Disaster Recovery](#)
 - [1. Purpose](#)
 - [2. Disaster Recovery Objectives](#)
 - [3. Backup Strategy \(Comprehensive\)](#)
 - [4. Recovery Procedures](#)
 - [5. Business Continuity Plan \(BCP\)](#)
 - [6. High Availability](#)
 - [7. Database Recovery](#)
 - [8. File Recovery](#)
 - [9. Cyberattack Recovery](#)
 - [10. DR Testing](#)
 - [11. DR Roles and Responsibilities](#)
 - [12. DR Communication](#)
 - [13. DR Runbooks](#)
 - [14. DR Budget and Resources](#)
 - [15. Open Questions for Approval](#)
 - [Approval Block](#)

SUOP ERP v1.0 — Enterprise Disaster Recovery

Field	Value
Document Version	1.0
Status	DRAFT — Awaiting Approval
Date	2026-07-11
Approval Required	Project Owner

Field	Value
Compliance	ISO 22301 (Business Continuity), FSSAI Cybersecurity

1. Purpose

This document defines how SUOP ERP v1.0 prevents, survives, and recovers from disasters. A “disaster” is any event that disrupts normal operation: hardware failure, region outage, cyberattack, data corruption, human error, or natural disaster.

Hard rule: Every recovery procedure in this document must be tested at least annually. Untested recovery plans are wishful thinking, not recovery plans.

2. Disaster Recovery Objectives

2.1 RPO and RTO Targets

Scenario	RPO (Data Loss)	RTO (Downtime)
Single-row accidental delete	0 (recoverable from PITR)	1 hour
Single-table accidental drop	0 (recoverable from PITR)	2 hours
Logical corruption (bad migration)	Up to 24 hours	4 hours
Application bug (data overwrite)	Up to 1 hour	2 hours
Database instance failure	0 (replica promotion)	30 minutes

Scenario	RPO (Data Loss)	RTO (Downtime)
Availability zone failure	0 (multi-AZ)	5 minutes
Region failure	Up to 1 minute (async replication)	30 minutes
Ransomware / cyberattack	Up to 24 hours (last clean backup)	24 hours
Total system loss (catastrophic)	Up to 24 hours (Glacier restore)	72 hours

2.2 Definitions

- **RPO (Recovery Point Objective):** Maximum acceptable data loss measured in time. “RPO of 1 hour” means at most 1 hour of data can be lost.
- **RTO (Recovery Time Objective):** Maximum acceptable downtime. “RTO of 4 hours” means system must be back online within 4 hours of disaster declaration.
- **DR (Disaster Recovery):** The process of restoring service after a disaster.
- **BCP (Business Continuity Plan):** The broader plan for keeping business running during disruption (including manual workarounds).

2.3 DR Tier Classification

Tier	Description	RTO	RPO	Cost
Tier 1 (Critical)	Always-on, zero data loss	<5 min	0	High
Tier 2 (Important)	Quick recovery, minimal loss	<1 hour	<15 min	Medium

Tier	Description	RTO	RPO	Cost
Tier 3 (Standard)	Hours of recovery acceptable	<8 hours	<24 hours	Low

SUOP components by tier: - **Tier 1:** Auth service, audit log (cannot lose audit data) - **Tier 2:** Backend API, database (transactional), Redis (cache) - **Tier 3:** File storage, search index (rebuildable)

3. Backup Strategy (Comprehensive)

3.1 Backup Layers

Layer 1 — Managed Automated Backups (Supabase/RDS): - **Frequency:** Continuous (WAL streaming) - **Retention:** 14 days - **Capability:** Point-in-time recovery (PITR) to any second in last 14 days - **Cross-region:** Automated backup replication to DR region - **Encryption:** At rest (KMS-managed keys)

Layer 2 — Logical Backups (pg_dump): - **Frequency:** Daily (3 AM UTC — off-peak) - **Retention:** 30 days daily, 12 months weekly, 7 years monthly (compliance) - **Storage:** S3 with SSE-KMS encryption - **Verification:** Daily restore-test job (restores to isolated DB, runs integrity checks) - **Format:** Custom format (`-Fc`) with compression

Layer 3 — File Storage Backups: - **S3 versioning:** Enabled on all buckets (recoverable from accidental delete) - **Cross-region replication:** All objects replicated to DR region - **Lifecycle:** Standard (3 years) → Standard-IA (3-7 years) → Glacier (7+ years) - **MinIO (dev):** Weekly `mc mirror` to local NAS

Layer 4 — Configuration Backups: - **Terraform state:** S3 backend with versioning - **Secrets:** Backed up via secrets manager export (encrypted) — quarterly - **GitHub:** Repo mirrored to Bitbucket (or AWS CodeCommit) weekly

3.2 Backup Encryption

- All backups encrypted at rest (S3 SSE-KMS or pg_dump --encrypt)
- Encryption keys in KMS, separate from data
- Decryption keys in secrets manager, different region from backups
- Key rotation: annually
- Key access: audited

3.3 Backup Integrity

- **Daily:** Restore-test job restores latest logical backup to isolated DB
 - Runs pg_checksums for physical integrity
 - Runs sample query suite (counts on key tables, sample row validation)
 - Alerts if any check fails
- **Weekly:** Full restore to staging environment
 - Runs full E2E test suite against restored data
 - Validates data consistency (row counts match production)
- **Monthly:** DR failover drill
 - Promote cross-region replica
 - Run smoke tests
 - Failback
- **Annual:** Full disaster simulation
 - Simulate region loss
 - Restore from Glacier backup
 - Document actual RTO and RPO

3.4 Backup Retention Policy

Backup Type	Retention	Storage	Purpose
PITR WAL	14 days	Supabase managed	Recovery to any second
Daily logical	30 days	S3 Standard	Quick restore for accidental delete

Backup Type	Retention	Storage	Purpose
Weekly logical	12 months	S3 Standard-IA	Mid-term recovery
Monthly logical	7 years	S3 Glacier	Compliance (FSSAI, GST, audit)
File storage	7 years	S3 Glacier	Compliance
Terraform state	Indefinite	S3 versioned	Infrastructure recovery
Secrets	1 year	Secrets manager	Secret recovery

4. Recovery Procedures

4.1 Recovery Scenario Catalog

#	Scenario	Trigger	Method	RTO
R1	Accidental row delete (within 14 days)	User report	PITR → extract row → insert back	1 hour
R2	Accidental table drop (within 14 days)	User report	PITR → restore table	2 hours
R3	Logical corruption (bad migration)	Failed deploy	Restore from nightly logical backup	4 hours

#	Scenario	Trigger	Method	RTO
R4	Application bug (data overwrite)	User report	PITR → extract correct data → restore	2 hours
R5	Database instance failure	Monitoring alert	Promote read replica	30 minutes
R6	Availability zone failure	Cloud provider	Auto-failover to standby AZ	5 minutes
R7	Region failure	Cloud provider	Promote cross-region replica	30 minutes
R8	Ransomware / cyberattack	Security team	Restore from last clean backup (offline)	24 hours
R9	Total system loss	Catastrophic event	Restore from Glacier monthly backup	72 hours
R10	File storage loss	S3 outage / corruption	Cross-region replica promotion	1 hour
R11	Redis loss	Redis outage	Rebuild from DB (cache is disposable)	15 minutes
R12	Configuration drift	Manual change detection	Terraform apply (idempotent)	30 minutes

4.2 Recovery Procedure — Logical Backup (R3)

Trigger: Failed deploy, corrupted data, bad migration

Steps: 1. Declare incident (Slack `#incidents` channel, page on-call) 2. Stop application writes (maintenance mode — return `503` from LB) 3. Provision new Postgres instance (same version as backup source) 4. Download latest clean logical backup from S3, verify checksum 5. `pg_restore --clean --if-exists --jobs=4 <backup>` to new instance 6. Run `pg_checksums` to verify data integrity 7. Run smoke tests (count of key tables, sample queries) 8. Switch application `DATABASE_URL` to new instance (via secrets manager update) 9. Restart application 10. Verify application functionality (full smoke test suite) 11. Document incident + post-mortem within 7 days 12. Decommission old instance after 7-day observation

Estimated time: 4 hours (RTO target met)

4.3 Recovery Procedure — PITR (R1, R2, R4)

Trigger: Accidental delete/drop, data overwrite

Steps: 1. Identify recovery timestamp T (just before incident) 2. Use Supabase/RDS console to restore to timestamp T (creates new instance) 3. New instance provisioned with data up to timestamp T 4. Connect to new instance, extract lost row(s) via SQL 5. Connect to production DB, insert lost row(s) via SQL (within transaction) 6. Verify data integrity 7. Decommission PITR instance 8. Audit log entry documenting recovery

Estimated time: 1-2 hours (RTO target met)

4.4 Recovery Procedure — Region Failover (R7)

Trigger: Cloud provider region outage

Steps: 1. Confirm region outage (Cloud status page, monitoring alerts) 2. Declare SEV-1 disaster 3. Promote cross-region replica to primary (Supabase/RDS console) 4. Update DNS to point to DR region (Route53 weighted policy — 100% to DR) 5. Update application `DATABASE_URL` to DR

region 6. Restart application in DR region 7. Run smoke tests 8. Notify users (status page, email) 9. When primary region recovers: re-establish replication (DR → primary) 10. Failback to primary during maintenance window 11. Document incident + post-mortem

Estimated time: 30 minutes (RTO target met) **RPO:** Up to 1 minute (async replication lag)

4.5 Recovery Procedure — Ransomware (R8)

Trigger: Security team detects ransomware encryption

Steps: 1. **ISOLATE** — Disconnect all systems from internet (prevent further encryption) 2. **IDENTIFY** — Determine extent of compromise (which systems, which data) 3. **PRESERVE** — Take disk images of compromised systems (forensics) 4. **ERADICATE** — Wipe compromised systems (cannot trust them) 5. **RESTORE** — Restore from last clean backup (verify backup integrity first) - Verify backup was taken BEFORE attack - Restore to fresh infrastructure (not compromised systems) 6. **VERIFY** — Run security scan on restored systems (no malware in DB) 7. **ROTATE** — Rotate all credentials (assume all compromised) 8. **RESUME** — Bring systems online progressively 9. **NOTIFY** — Notify stakeholders, regulators (FSSAI, CERT-In within 72 hours per DPDP) 10. **POST-MORTEM** — Within 7 days; root cause, action items

Estimated time: 24 hours (RTO target met) **RPO:** Up to 24 hours (last clean backup)

4.6 Recovery Procedure — Total System Loss (R9)

Trigger: Catastrophic event destroys primary region + DR region (rare)

Steps: 1. Provision new infrastructure via Terraform (different cloud provider if needed) 2. Restore monthly Glacier backup (24-hour retrieval time) 3. Restore file storage from Glacier 4. Restore secrets from secrets manager backup 5. Restore configuration from Terraform state 6. Apply pending migrations 7. Run smoke tests 8. Bring systems online 9. Notify stakeholders

Estimated time: 72 hours (RTO target met) **RPO:** Up to 1 month (Glacier monthly backup)

4.7 Recovery Procedure — Redis Loss (R11)

Trigger: Redis outage, cache corruption

Steps: 1. Redis is disposable — no data loss concern (cache only) 2. Application continues to function (cache miss → DB query) 3. Provision new Redis instance 4. Update application REDIS_URL 5. Application reconnects automatically 6. Cache warms over time as requests come in 7. Optional: trigger cache warming job for hot data

Estimated time: 15 minutes (RTO target met) **RPO:** N/A (cache is rebuildable)

5. Business Continuity Plan (BCP)

5.1 BCP Scope

When systems are down, business operations must continue (manually if necessary) until systems recover.

5.2 Manual Workarounds

Operation	Manual Workaround	Responsible
Goods receipt	Paper GRN form; enter into system when recovered	Warehouse manager
Production order	Paper traveler; system updated post-recovery	Production supervisor
Quality inspection	Paper checklist; system updated post-recovery	Quality inspector

Operation	Manual Workaround	Responsible
Stock issue	Paper issue slip; system updated post-recovery	Warehouse operator
Dispatch	Paper delivery challan; system updated post-recovery	Dispatch supervisor
Customer complaint	Email log; system updated post-recovery	Customer service
NCR creation	Paper NCR form; system updated post-recovery	Quality inspector

5.3 BCP Roles

Role	Responsibility
Incident Commander	Coordinates response, makes go/no-go decisions
Operations Lead	Manages manual workarounds
Communications Lead	Notifies stakeholders, customers
Technical Lead	Executes recovery procedures
Safety Lead	Ensures food safety during outage

5.4 BCP Communication Plan

Audience	Channel	Frequency
Internal team	Slack #incidents	Real-time updates
Employees		Hourly

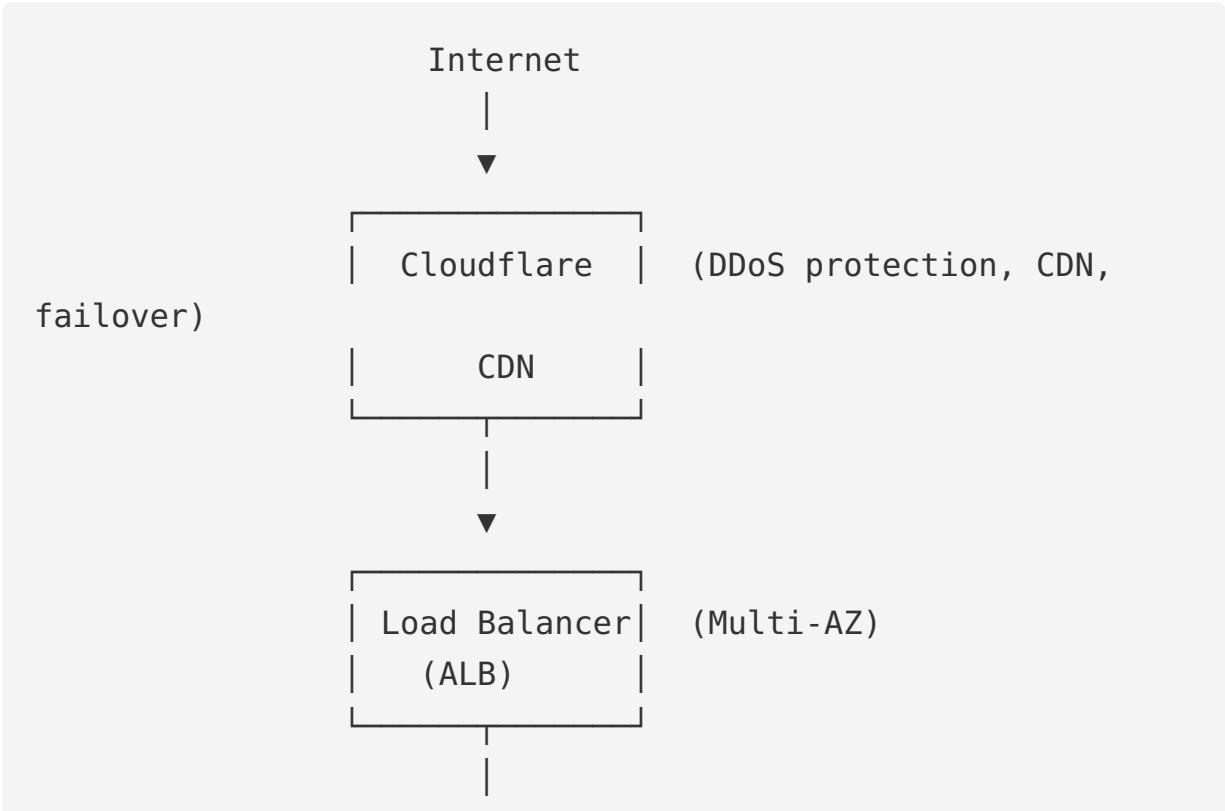
Audience	Channel	Frequency
	Email + Slack #announcements	
Customers	Status page + email	Hourly
Regulators (FSSAI, CERT-In)	Phone + email	Within 72 hours (DPDP)
Public	Status page + blog post	After containment

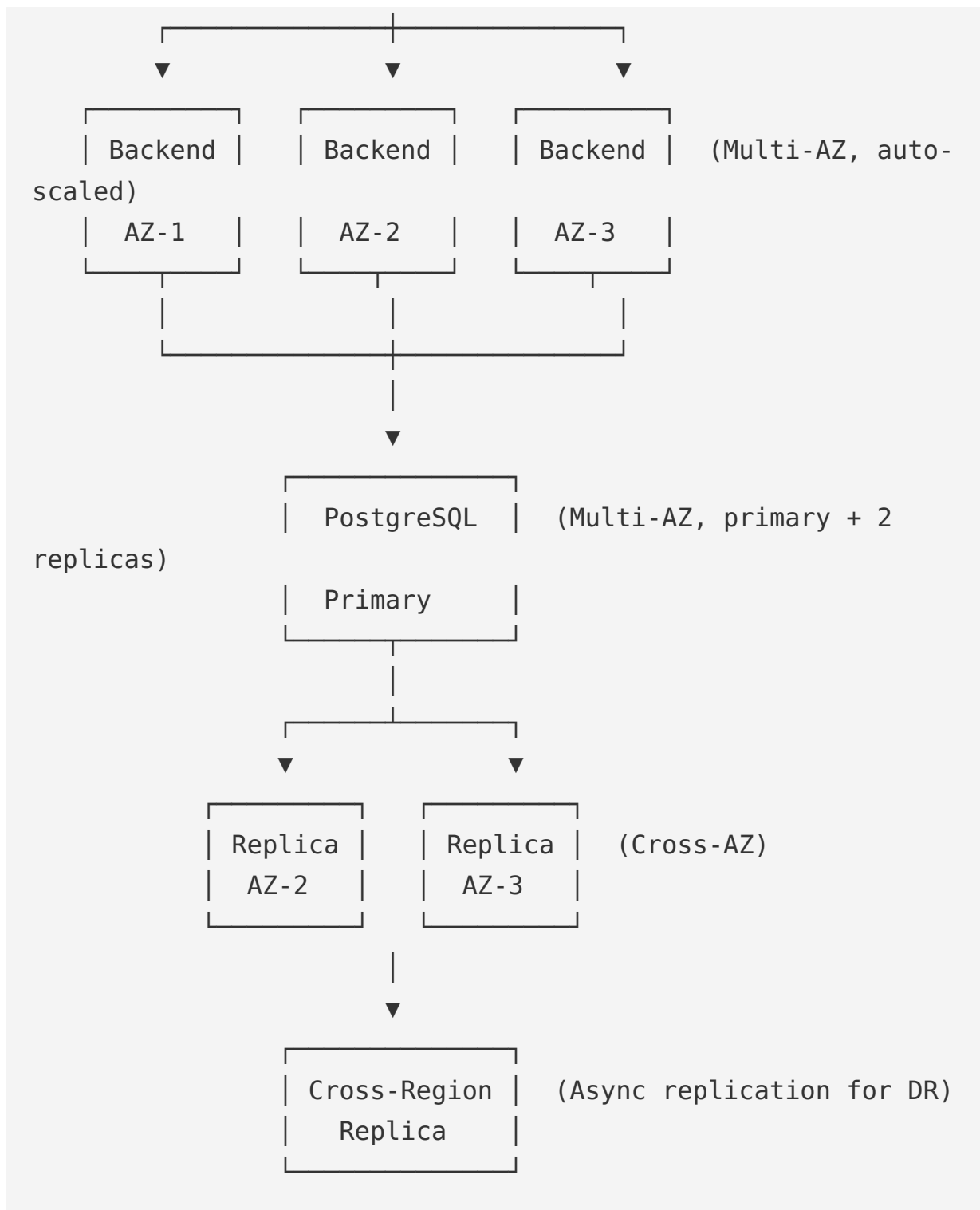
5.5 BCP Testing

- **Quarterly:** Tabletop exercise (walk-through of BCP)
- **Semi-annually:** Partial BCP test (one operation manual for 4 hours)
- **Annually:** Full BCP test (all operations manual for 8 hours)

6. High Availability

6.1 HA Architecture





6.2 HA Configuration

- **Multi-AZ:** Primary in AZ-1, synchronous replicas in AZ-2 and AZ-3
- **Auto-failover:** Primary failure → replica promoted automatically (RDS Multi-AZ)
- **Read replicas:** 2 read replicas for read-heavy workloads (dashboards, reports)

- **Cross-region:** Async replica in DR region (RPO ~1 min)
- **Load balancer:** Multi-AZ ALB; health checks route to healthy instances only
- **Backend:** ECS tasks across 3 AZs; min 2 tasks for HA
- **Redis:** Single instance (cache is disposable); future: Redis Cluster for HA

6.3 Failure Modes

Failure	Detection	Recovery
Single backend task crash	ALB health check	ALB routes to healthy; ECS starts new task
Single AZ failure	ALB health check	ALB routes to healthy AZs; auto-scaling adds tasks
Primary DB failure	RDS health check	Auto-promote standby replica (<30s)
Redis failure	App health check	App degrades gracefully (cache miss → DB)
Load balancer failure	Cloudflare health check	Cloudflare routes to standby LB
Region failure	External uptime monitor	Manual failover to DR region

6.4 No Single Point of Failure

- **Application:** Multiple instances across AZs
- **Database:** Multi-AZ with auto-failover
- **Load balancer:** Managed service (AWS handles HA)
- **DNS:** Route53 with health checks + failover routing
- **CDN:** Cloudflare (globally distributed)
- **Redis:** Single instance today (acceptable — cache); cluster future

7. Database Recovery

7.1 Recovery Methods

Method	When	Speed	Granularity
PITR (Point-in-Time Recovery)	Within 14 days of incident	Minutes to hours	Second-level
Logical backup restore	Beyond 14 days	Hours to days	Day-level
Replica promotion	Primary failure	Seconds to minutes	Real-time
Cross-region failover	Region failure	Minutes	Up to 1 min lag
Glacier restore	Catastrophic loss	24+ hours	Month-level

7.2 Database Recovery Steps (General)

1. **Identify** — What was lost? When? How?
2. **Isolate** — Stop writes to prevent further loss
3. **Choose method** — PITR vs logical vs replica
4. **Restore** — Execute recovery procedure
5. **Verify** — Run integrity checks + smoke tests
6. **Switch** — Point application to restored DB
7. **Audit** — Log recovery in audit trail
8. **Post-mortem** — Document + prevent recurrence

7.3 Database Integrity Verification

After recovery: - `pg_checksums` — physical integrity -
`pg_stat_user_tables` — row counts match expectations - Foreign key

validation:

`SELECT * FROM child WHERE parent_id NOT IN (SELECT id FROM parent)` - Audit log integrity: re-compute hash chain; verify no tampering - Business rule validation: spot-check critical entities (POs, GRNs, ledger entries)

8. File Recovery

8.1 File Storage Recovery

S3 versioning: Every object has all versions; accidental delete = remove delete marker

Cross-region replication: All objects replicated to DR region

Glacier archive: 7+ year old files in Glacier; restore takes 1-5 hours (Expedited), 3-5 hours (Standard), 5-12 hours (Bulk)

8.2 File Recovery Steps

1. Identify lost file (file ID, S3 key)
2. Check S3 versioning — restore previous version (instant)
3. If version unavailable — check DR region replica (instant)
4. If replica unavailable — restore from Glacier (hours)
5. Verify file integrity (checksum)
6. Update application metadata if file ID changed

8.3 File Recovery SLAs

Scenario	RTO
Accidental delete (S3 versioning)	<5 min
S3 bucket loss (cross-region replica)	<30 min
Region loss (Glacier restore)	<12 hours
Total file storage loss	<24 hours (Expedited Glacier)

9. Cyberattack Recovery

9.1 Cyberattack Scenarios

Attack	Impact	Recovery
Ransomware	Data encrypted	Restore from clean backup; rotate all credentials
Data breach (exfiltration)	Data stolen	Notify regulators (72h), customers; forensics; patch vulnerability
Account takeover	Unauthorized access	Revoke sessions; reset passwords; audit log review
DDoS	Service unavailable	Cloudflare absorbs; rate limit; auto-scale
SQL injection	Data leaked/modified	Patch vulnerability; audit affected data; restore if modified
Insider threat	Data deleted/leaked	Revoke access; forensics; legal action; restore from backup

9.2 Cyberattack Recovery Procedure

1. **Detect** — Monitoring alert, user report, security researcher
2. **Isolate** — Disconnect affected systems (without destroying evidence)
3. **Investigate** — Logs, audit trail, forensics
4. **Contain** — Block attacker (revoke tokens, block IPs, rotate credentials)
5. **Eradicate** — Apply fix, remove malware, close vulnerability

6. **Restore** — From clean backup if data corrupted
7. **Verify** — Security scan of restored systems
8. **Resume** — Bring systems online progressively
9. **Notify** — Regulators (72h), customers, public
10. **Post-mortem** — Root cause, action items, lessons learned

9.3 Cyberattack Recovery Tools

- **Forensics:** AWS GuardDuty, Detective
 - **Backup verification:** Checksums, restore-test
 - **Credential rotation:** Secrets manager bulk rotation
 - **Communication:** Pre-drafted templates (breach notification, customer email)
-

10. DR Testing

10.1 DR Test Schedule

Test	Frequency	Scope
Backup restore-test	Daily	Latest logical backup to isolated DB
Full restore-test	Weekly	Full restore to staging + E2E suite
DR failover drill	Monthly	Promote cross-region replica
Tabletop exercise	Quarterly	Walk-through of DR procedures
Partial BCP test	Semi-annual	One operation manual for 4 hours
Full BCP test	Annually	All operations manual for 8 hours

Test	Frequency	Scope
Full disaster simulation	Annually	Region loss, restore from Glacier

10.2 DR Test Documentation

Each test produces a report: - Test scenario - Date + participants - Steps executed - Actual RTO achieved - Actual RPO achieved - Issues encountered - Action items - Lessons learned

10.3 DR Test Failures

If DR test fails: - Declare SEV-2 incident - Stop deploying to production until DR capability restored - Root-cause analysis within 7 days - Fix verified before resuming deploys

11. DR Roles and Responsibilities

11.1 DR Team

Role	Responsibility	Backup
Incident Commander	Coordinates response, go/no-go decisions	Operations Lead
Operations Lead	Executes recovery procedures	Senior Engineer
Communications Lead	Notifies stakeholders	Marketing Lead
Technical Lead	Deep technical recovery	Senior Engineer
Safety Lead	Food safety during outage	Quality Manager

Role	Responsibility	Backup
Legal Lead	Regulatory notifications	External counsel
Customer Liaison	Customer communication	Customer Success

11.2 DR Contact Tree

On-call Engineer (24/7)

↓

Incident Commander

↓

- ├─ Operations Lead → Engineering team
- ├─ Communications Lead → Status page, Slack, email
- ├─ Technical Lead → Recovery execution
- ├─ Safety Lead → Food safety decisions
- ├─ Legal Lead → Regulatory notification
- └─ Customer Liaison → Customer communication

11.3 DR Activation

Any team member can declare a disaster by: - Paging PagerDuty with “DISASTER” keyword - Creating incident in `#incidents` Slack channel - Calling DR hotline (forwarded to on-call)

Once declared, Incident Commander takes over coordination.

12. DR Communication

12.1 Internal Communication

- **Slack `#incidents`** : Real-time updates during incident
- **Slack `#announcements`** : Hourly employee updates
- **Status page (internal)**: Current incident status

- **Phone bridge:** Open conference call for DR team

12.2 External Communication

- **Status page (public):** status.sudhamrit.com
- **Customer email:** Within 1 hour of incident declaration
- **Customer update:** Hourly until resolved
- **Resolution email:** Within 1 hour of resolution
- **Post-mortem blog:** Within 7 days (transparency)

12.3 Regulatory Notification

Regulator	Trigger	Deadline
FSSAI	Food safety data compromised	72 hours
CERT-In	Cybersecurity incident	6 hours (new 2022 mandate)
DPDP (Data Protection)	Personal data breach	72 hours
GST authorities	Invoice data compromised	24 hours
Local police	Cybercrime (ransomware, hack)	24 hours

12.4 Communication Templates

Pre-drafted templates for: - Customer incident notification - Customer resolution notification - Regulator notification - Public blog post - Internal employee update - Media statement

Templates in [docs/runbooks/communication-templates/](#).

13. DR Runbooks

Each recovery scenario has a detailed runbook:

Runbook	Scenario
RB-01-row-recovery.md	Single row accidental delete
RB-02-table-recovery.md	Single table accidental drop
RB-03-logical-restore.md	Logical corruption / bad migration
RB-04-pitr-restore.md	PITR recovery
RB-05-db-failover.md	DB instance failure
RB-06-az-failover.md	Availability zone failure
RB-07-region-failover.md	Region failure
RB-08-ransomware.md	Ransomware recovery
RB-09-catastrophic.md	Total system loss
RB-10-file-recovery.md	File storage loss
RB-11-redis-loss.md	Redis loss
RB-12-config-drift.md	Configuration drift
RB-13-ddos.md	DDoS attack
RB-14-data-breach.md	Data breach
RB-15-insider-threat.md	Insider threat

Each runbook includes: - Trigger criteria - Step-by-step procedure - Required tools + access - Verification steps - Rollback (if recovery fails) - Communication templates - Post-recovery tasks

14. DR Budget and Resources

14.1 DR Infrastructure Cost

Resource	Purpose	Monthly Cost (Est.)
Cross-region DB replica	DR region standby	\$200-500
Cross-region S3 replication	File storage DR	\$50-100
Glacier storage (7-year archive)	Long-term retention	\$20-50
PagerDuty (DR team)	Incident alerting	\$50-100
Status page (public)	Customer communication	\$30-50
DR test infrastructure	Monthly drill	\$100-200
Total		\$450-1000/month

14.2 DR Time Investment

Activity	Frequency	Time per Session	Annual Hours
Tabletop exercise	Quarterly	2 hours	8
DR failover drill	Monthly	1 hour	12
Full restore test	Weekly	30 min	26
Full BCP test	Annually	8 hours	8
Full disaster simulation	Annually	16 hours	16

Activity	Frequency	Time per Session	Annual Hours
Total			70 hours/year

15. Open Questions for Approval

#	Decision	Recommendation	Alternatives
Q-DR1	RPO for region failure	1 minute (async replication)	0 (sync — expensive)
Q-DR2	RTO for ransomware	24 hours	8 hours (more strict)
Q-DR3	DR region	AWS ap-south-1 (Mumbai) primary; ap-south-2 (Hyderabad) DR	Different cloud (Azure)
Q-DR4	DR test frequency	Monthly failover, annual full	Quarterly (less strict)
Q-DR5	Glacier retrieval tier	Standard (3-5 hours)	Expedited (1-5 min, higher cost)
Q-DR6	Customer notification SLA	1 hour	30 min (more strict)
Q-DR7	Regulator notification (CERT-In)	6 hours (per 2022 mandate)	N/A (mandated)
Q-DR8	DR infrastructure	Always-on cross-region replica	Pilot light (start on demand)

#	Decision	Recommendation	Alternatives
Q-DR9	BCP manual workaround scope	Critical operations only	All operations
Q-DR10	DR team size	7 roles	Larger (more redundancy)

Approval Block

Approved by: _____ **Date:** _____

End of Enterprise Disaster Recovery Document